

**НЕКОММЕРЧЕСКОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО
«КАЗАХСКИЙ НАЦИОНАЛЬНЫЙ ПЕДАГОГИЧЕСКИЙ
УНИВЕРСИТЕТ ИМЕНИ АБАЯ»**



УТВЕРЖДЕНО

Решением Правления

НАО «Казахский национальный педагогический университет имени Абая»

от «10» сентября 2025 года

Протокол №

Председатель Правления - Ректор

Тілеп Б. А.



**Политика информационной безопасности
Некоммерческого акционерного общества «Казахский национальный
педагогический университет имени Абая»**

Алматы, 2025



Оглавление

1 Общие положения.....	3
2 Область применения.....	4
3 Цель политики.....	5
4 Основные задачи Политики.....	5
5 Организационное обеспечение информационной безопасности.....	5
6 Меры обеспечения безопасности.....	7
7 Принципы управления информационной безопасностью.....	8
8 Требования к организации информационной безопасности.....	9
9 Обязанности руководства.....	11
10 Ответственность пользователей.....	11
11 Обязанности персонала по обеспечению безопасности.....	13
12 Ответственность за нарушение Политики.....	14
13 Заключительные положения.....	15
Лист регистрации изменений.....	16
Лист согласования.....	17

Глава 1. Общие положения

1.1 Настоящая Политика информационной безопасности некоммерческого акционерного общества «Казахский национальный педагогический университет имени Абая» (далее – «Университет») разработана в соответствии с законодательством Республики Казахстан, а также требованиями международных стандартов управления информационной безопасностью.

Настоящий документ разработан в соответствии со следующими нормативно-правовыми актами и документами:

- Закон Республики Казахстан от 24 ноября 2015 года № 418-V ЗРК. «Об информатизации»;
- Закон Республики Казахстан от 21 мая 2013 года N 94-V. «О персональных данных и их защите»;
- Постановление Правительства Республики Казахстан от 20.12.2016г. №832 «Об утверждении единых требований в области информационно-коммуникационных технологий и обеспечения информационной безопасности»;
- СТ РК ИСО/МЭК 27002-2009 «Информационные технологии. Средства обеспечения. Свод правил по управлению защитой информации».

1.2 Политика информационной безопасности (далее – Политика ИБ) устанавливает основные принципы, направления и требования к защите информации, обеспечивая ее конфиденциальность, целостность и доступность.

1.4 Задачи политики:

- Защищённость всех информационных активов Университета;
- Минимизация рисков утечек, сбоев и других инцидентов;
- Соответствие политики информационной безопасности законодательным требованиям РК;
- Повышение эффективности процессов управления безопасностью.

1.5 Данная политика распространяется на всех пользователей, получающих доступ к информационным системам и ресурсам Университета.

2. Термины, использованные в Политике:

В настоящей Политике используются следующие основные термины и определения:

Активы – материальные и нематериальные ресурсы Университета;

IT-инфраструктура – совокупность всех аппаратных и программных средств, которые используются для обработки, хранения и передачи информации в Университете;

Информационная безопасность (далее - ИБ) – процесс защиты данных и информационных систем от несанкционированного доступа, утечек, потерь, изменений и других угроз;

Инцидент информационной безопасности – любое событие, которое нарушает или может нарушить информационную безопасность, включая утечку данных, несанкционированный доступ или повреждение данных;

Уязвимость – слабость системы или процесса, которая может быть использована для несанкционированного доступа или других нарушений безопасности;

Угроза – потенциальная причина инцидента, который может нанести ущерб системе или организации;

Вредоносное ПО – программы, которые могут нарушать работоспособность системы или утечку данных (вирусы, шпионские программы и т.д.);

Резервное копирование – процесс создания копий данных для их восстановления в случае потери или повреждения исходных данных;

Аудит информационной безопасности – процесс регулярной проверки системы безопасности на соответствие установленным нормам и стандартам;

Шифрование данных – процесс преобразования информации в код, который может быть расшифрован только с использованием ключа для защиты конфиденциальности данных;

Интернет-ресурсы – онлайн-платформы и различные цифровые сервисы, доступные в Интернете, которые могут использоваться для выполнения профессиональных задач или получение информации, общение и обучение;

Конфиденциальная информация – информация, которую нужно держать в секрете и не передавать без разрешения;

Несанкционированное действие – это действие, выполненное без должного разрешения или вне установленных правил и процедур, которое нарушает безопасность, целостность или доступность информации или системы;

Непрерывность – способность системы или процесса поддерживать свою функциональность и доступность на должном уровне без перерывов, несмотря на возможные сбои, инциденты или чрезвычайные ситуации.

Глава 2. Область применения

Настоящее Положение об информационной безопасности (далее – Положение) определяет основные принципы, направления и требования по защите информации, является основой для обеспечения режима информационной безопасности, служит руководством при разработке соответствующих Политик, Правил, Инструкций.

В область действия политики входят все направления обеспечения информационной безопасности, в том числе управление рисками, определение ответственности сотрудников, применение технических и организационных мер защиты, а также соответствие требованиям законодательства и

нормативных правовых актов Республики Казахстан в сфере информационной безопасности.

Глава 3. Цель политики

Данная Политика разработана для гарантии безопасности IT-инфраструктуры и автоматизированных систем Университета, а также предотвращения любого рода потерь – материальных, физических или иных – которые могут быть вызваны непреднамеренными или намеренными действиями, затрагивающими информацию, средства её хранения, этапы обработки и передачи. Политика направлена на снижение вероятности информационных угроз и поддержание стабильной работы информационных систем.

Глава 4. Основные задачи Политики

- 1) защита информации, ограниченной в распространении, включая банковские данные, коммерческую тайну и другую конфиденциальную информацию, признанную служебной или охраняемой законом, осуществляется в соответствии с Положением об определении информации о НАО «Казахский национальный педагогический университет имени Абая».
- 2) Предвидение и оперативное обнаружение возможных угроз информационной безопасности, а также анализ причин и факторов, приводящих к финансовым потерям, материальному ущербу или сбоям в работе информационных систем, являются ключевыми задачами.
- 3) создать условия для стабильной и защищенной деятельности Университета, минимизируя вероятность реализации угроз безопасности информационных ресурсов.
- 4) разрабатывать действенный механизм быстрого реагирования на инциденты информационной безопасности и негативные явления в работе Университета, с применением нормативных, юридических, организационных и технических средств защиты.
- 5) обеспечивать условия для оперативного устранения последствий и максимального возмещения ущерба, нанесенного неправомерными действиями физических и/или юридических лиц.

Глава 5. Организационное обеспечение информационной безопасности

Задачи обеспечения безопасности информационных ресурсов решаются следующими организационными методами:

- разработкой и осуществлением разрешительной системы допуска работников к работам с документами и сведениями конфиденциального характера;

- установлением единого порядка хранения и обращения конфиденциальной информации (документов, носителей информации);

- координацией работ по защите информации, обрабатываемой и передаваемой средствами и системами вычислительной техники и связи.

Для обеспечения информационной безопасности при работе с сотрудником Университета ключевыми организационными мерами выступают:

- заключение трудовых договоров и соблюдение требований, регламентирующих режим информационной безопасности и сохранность конфиденциальной информации;

- проведение первоначального инструктажа, периодического обучения и повышения квалификации работников Университета в области информационной безопасности.

- система распределения обязанностей между отдельными работниками может в значительной мере способствовать повышению общего уровня информационной безопасности.

Этого можно достичь следующими методами:

- минимизация данных, доступных работникам. Организация технологического процесса сбора и обработки информации и планирование помещений должны по мере возможности исключать или сводить к минимуму контакты персонала в процессе выполнения работ. Каждый работник должен знать все о своей работе и связанных с нею ограничениях, а также четко представлять последствия нарушения этих ограничений;

- разделение полномочий и дублирование контроля. В системах с высокими требованиями по обеспечению сохранности данных ответственная работа или процедура (например, изменение статуса электронного документа) выполняется после подтверждения ее необходимости двумя работниками. Временные или вновь принятые работники, а также работники, проходящие обучение, стажировку, практику не должны самостоятельно выполнять ответственные задания.

Административные меры защиты информации предполагают:

- обеспечение физической сохранности автоматизированной системы и дополнительного оборудования;

- организацию контроля доступа и режима выполнения работ

персоналом подразделения информационных технологий;

- инспектирование правильности и полноты выполнения персоналом подразделения информационных технологий мер по обеспечению сохранности необходимых дубликатов файлов, библиотеки программ, оборудования системы;

Практическую проверку функционирования отдельных мер защиты:

- предотвращения недозволенных изменений программ и оборудования, контроль всех процедур, производимых с файлами на носителях и т.д.;
- проверку машинных и ручных протоколов выполнения работ со стороны пользователей;
- ознакомление работников Управления информационных технологий со всеми новыми разработками по обеспечению сохранности данных.

Глава 6. Меры обеспечения безопасности

Меры обеспечения безопасности информационных систем подразделяются на:

- законодательные (правовые) действия;
- организационные мероприятия;
- технические меры;
- морально-этические методы;
- физическая защита.

6.1. Законодательные (правовые) меры защиты. К правовым мерам защиты относятся действующие в Республике Казахстан нормативные и правовые акты, регламентирующие правила обращения с информацией, закрепляющие права и обязанности участников информационных отношений в процессе ее обработки и использования, а также устанавливающие ответственность за нарушения этих правил, препятствуя тем самым неправомерному использованию информации и являющиеся сдерживающим фактором для потенциальных нарушителей.

Правовые меры защиты носят в основном упреждающий, профилактический характер и требуют постоянной разъяснительной работы с пользователями и обслуживающим персоналом системы.

6.2. Организационные меры защиты. Организационные меры защиты – это меры организационного характера, регламентирующие процессы функционирования системы обработки данных в Обществе, использование ее ресурсов, деятельность обслуживающего персонала информационных систем

обработки данных Общества, а также порядок взаимодействия пользователей с системой таким образом, чтобы в наибольшей степени затруднить или исключить возможность реализации угроз безопасности или снизить размер потерь в случае их реализации.

6.3. Технические меры защиты. Технические меры защиты основаны на использовании различных электронных устройств и специальных программ, входящих в состав автоматизированной информационной системы Общества и выполняющих (самостоятельно или в комплексе с другими средствами) функции защиты (идентификацию и аутентификацию пользователей, разграничение доступа к ресурсам, регистрацию событий, криптографическую защиту информации и т.д.).

6.4. Морально-этические методы. Методы защиты, опирающиеся на нравственные и этические принципы, представляют собой способы поддержания безопасности, сложившихся из общепринятых правил и установлений в обществе или конкретной группе.

6.5. Физические меры защиты. Физические меры защиты основаны на применении разного рода механических, электро- или электронно-механических устройств и сооружений, специально предназначенных для создания физических препятствий на возможных путях проникновения и доступа потенциальных нарушителей к компонентам информационной системы обработки данных Общества и защищаемой информации, а также технических средств визуального наблюдения, связи и охранной сигнализации.

Глава 7. Принципы управления информационной безопасностью

1) Конфиденциальность. Все персональные данные обучающихся, преподавателей и сотрудников, а также академические и административные, должны быть защищены от несанкционированного доступа, утечек и потерь. Защита конфиденциальной информации является основой доверия к Университету, и все меры должны быть направлены на предотвращение нарушений безопасности данных.

2) Целостность. Данные должны быть корректными и не подвергаться случайным или преднамеренным изменениям, удалению или замене без предварительного согласия. Вся информация должна быть доступна в полном объеме, без пропущенных или повреждённых частей. Никто не должен иметь возможность изменить данные без соответствующего разрешения.

3) Доступность. Пользователи должны иметь возможность получать доступ к информации и системам без задержек или перебоев. Системы должны быть устойчивы к сбоям оборудования, программного обеспечения или кибератакам. Если доступ был утрачен, системы должны быть восстановлены

как можно быстрее. Серверы, сети и другие ресурсы должны иметь достаточную производительность, чтобы поддерживать работу всех пользователей.

4) Соблюдение нормативных требований. Вся деятельность Университета в области информационной безопасности должна соответствовать требованиям законодательства РК, а также международным стандартам.

5) Этичное использование данных. Вся работа с данными должна строиться на этических принципах. Это подразумевает запрет на манипуляцию, злоупотребление или незаконное использование информации, находящейся в распоряжении Университета.

6) Инновации и адаптация. Системы информационной безопасности должны постоянно адаптироваться к изменениям в технологиях, новым угрозам и требованиям. Это включает внедрение новых методов защиты и обновление используемых инструментов.

7) Ответственность. Все сотрудники несут ответственность за защиту информации, с которой они работают, и обязаны соблюдать внутренние нормативные документы, политики и процедуры, связанные с информационной безопасностью.

Глава 8. Требования к организации информационной безопасности

8.1 Для обеспечения защиты активов Университета необходимо регулярно проводить инвентаризацию, классификацию и маркировку активов. Эти процессы регламентируются внутренним документом «Правила идентификации, классификации и маркировки активов, связанных со средствами обработки информации информационных систем и IT инфраструктуры».

8.2 Управление угрозами и рисками информационной безопасности осуществляется на основе «Методики оценки рисков ИБ». Это включает в себя идентификацию потенциальных угроз, анализ их вероятности и последствий, а также реализацию мероприятий, предусмотренных «Планом обработки угроз (рисков) ИБ». Для обеспечения полноты управления рисками используется «Каталог угроз (рисков) ИБ», содержащий классифицированные угрозы, их описание и потенциальные последствия.

8.3 Для обеспечения надлежащего контроля и выявления уязвимостей необходимо проводить регулярные внутренние аудиты, которые выполняются в соответствии с «Правилами проведения внутреннего аудита информационной безопасности IT инфраструктуры».

8.4 Для предотвращения инцидентов, связанных с вредоносным программным обеспечением, Университет обязан обеспечивать антивирусный контроль, а также регулировать использование мобильных устройств, внешних носителей информации, Интернета и электронной почты. Эти меры определяются в «Правилах организации антивирусного контроля,

использования мобильных устройств, носителей информации, Интернета и электронной почты». Сотрудники обязаны соблюдать установленные процедуры и пользоваться только разрешёнными ресурсами и оборудованием.

8.5 Обеспечение непрерывности деятельности Университета при возникновении инцидентов или внештатных ситуаций регламентируется «Планом мероприятий по обеспечению непрерывной работы и восстановлению работоспособности активов, связанных со средствами обработки информации».

8.6 Действия администратора для обеспечения защиты, доступности и целостности данных в информационных системах осуществляется в соответствии с «Руководством администратора по сопровождению объекта информатизации, резервному копированию и восстановлению информации».

8.7 Реагирование на инциденты информационной безопасности, а также на кризисные ситуации осуществляется в соответствии с «Инструкцией о порядке действий пользователей по реагированию на инциденты ИБ и во внештатных (кризисных) ситуациях». Документ определяет порядок действий для всех сотрудников и пользователей в случае обнаружения нарушений или угроз.

8.8 Для регистрации всех инцидентов, связанных с нарушением информационной безопасности, а также учёта внештатных ситуаций, которые могут повлиять на безопасность данных и системы ведётся «Журнал регистрации инцидентов ИБ и учета внештатных ситуаций».

8.9 Для учёта всех посетителей серверных ведётся «Журнал посещения серверных помещений».

8.10 Для фиксации всех изменений и подключений в системе кабельных соединений ведётся «Журнал учета кабельных соединений».

8.11 Для регистрации всех операций по созданию, хранению и восстановлению резервных копий данных ведётся «Журнал учета резервных копий».

8.12 Оценка уязвимостей сетевых ресурсов проводится на регулярной основе. Результаты оценок фиксируются в «Отчёте о проведении оценки уязвимости сетевых ресурсов».

8.13 Активы, находящиеся в территории организации, должны быть защищены в соответствии с «Правилами обеспечения физической защиты средств обработки информации и безопасности информационных ресурсов».

8.14 Все вышеперечисленные меры направлены на реализацию комплексного подхода к обеспечению информационной безопасности и для соблюдения требований Постановления Правительства Республики Казахстан от 20 декабря 2016 года № 832. «Об утверждении единых требований в области информационно-коммуникационных технологий и обеспечения информационной безопасности».

Глава 9. Обязанности руководства

Руководство организации должно постоянно поддерживать заданный уровень информационной безопасности путем внедрения системы менеджмента, а также путем распределения обязанностей и ответственности персонала за ее обеспечение.

Согласно СТ РК ИСО/МЭК 27002-2009 «Информационные технологии. Средства обеспечения. Свод правил по управлению защитой информации», руководство Университета выполняет следующие функции:

- обеспечение целей информационной безопасности в соответствии с организационными требованиями и использование их в соответствующих процессах;
- утверждение и пересмотр политики информационной безопасности;
- оценка эффективности внедрения политики информационной безопасности;
- обеспечение четкого управления и реальной поддержки со стороны руководства инициатив в области информационной безопасности;
- выделение необходимых ресурсов для обеспечения информационной безопасности;
- утверждение распределения основных обязанностей и функций в отношении информационной безопасности в организации;
- внедрение планов и программ по поддержке обеспечения информационной безопасности;
- обеспечение согласованности средств управления информационной безопасности в организации.

Глава 10. Ответственность пользователей

В соответствии с требованиями СТ РК ИСО/МЭК 27002-2009 «Информационные технологии. Средства обеспечения. Свод правил по управлению защитой информации», пользователи должны быть осведомлены о своих обязанностях по использованию эффективных мероприятий по управлению доступом, в частности, в отношении паролей и безопасности оборудования, с которым они работают.

10.1 Использование паролей

Пользователям рекомендуется:

- сохранять конфиденциальность паролей и не передавать их другим лицам;
- избегать записи паролей на бумаге, в файлах на компьютере или на внешних устройствах, если они не хранятся в безопасном месте (например, в специально защищенном приложении);
- изменять пароли при малейшем подозрении на их утечку или взлом системы;
- создавать надежные пароли, которые легко запоминаются; невозможно угадать или вычислить, используя личную информацию

(например, имя, дату рождения, номер телефона); не состоят из простых слов или комбинаций, которые можно найти в словарях; не содержат одинаковых символов подряд и не состоят только из цифр или только из букв;

- регулярно менять пароли через определенные промежутки времени или после нескольких входов в систему. Для важных учетных записей (например, с административным доступом) пароли следует менять чаще;

- менять временный пароль, выданный при регистрации в системе, на собственный сразу при первом входе;

- не использовать функции, которые автоматически запоминают и вводят пароли (например, в браузерах или других программах);

- избегать совместного использования одного пароля несколькими людьми;

- использовать разные пароли для рабочих и личных целей.

10.2 Оборудование, оставленное пользователем без присмотра

Пользователям рекомендуется:

- завершать активные сеансы после окончания работы, особенно если компьютер или устройство не блокируются автоматически;

- полностью отключаться от системы или приложения, когда работа завершена (необходимо выйти из учетной записи или завершить сеанс);

- защищать компьютеры и устройства от кражи, повреждений или несанкционированного доступа.

10.3 Политика «чистого стола» и «чистого экрана»

Пользователям рекомендуется:

- не оставлять документы, записки или другие материалы с конфиденциальной информацией на рабочем месте, особенно в конце рабочего дня, хранить такие документы в сейфах или запираемых шкафах;

- при каждом уходе с рабочего места, даже на короткое время, блокировать экран компьютера, используя функцию блокировки, либо включить автоматическую блокировку;

- уничтожать ненужные бумажные носители с конфиденциальной информацией только с использованием shreddera или других средств, исключающих возможность восстановления данных;

- напечатанные документы с важной или конфиденциальной информацией необходимо изымать из принтеров немедленно.

10.4 Контроль сетевого доступа

Пользователям рекомендуется:

- подключаться только к тем сетевым ресурсам и системам, которые необходимы для выполнения профессиональных обязанностей;

- исключать использование служебных учетных записей для личных нужд;

- посещать только те веб-сайты, которые разрешены Университетом в соответствии с внутренними нормативными документами;

- не открывать подозрительные ссылки, вложения и файлы из ненадежных источников;

- использовать только разрешенные приложения, одобренные Университетом.

10.5 Обращение с конфиденциальной информацией

Пользователи должны:

- не разглашать и не передавать конфиденциальную информацию (личные данные студентов и сотрудников, академическая информация, научные исследования, разработки, внутренние отчеты, бюджеты, планы, и т.д.) посторонним лицам;

- следить за тем, чтобы конфиденциальная информация не была доступна третьим лицам без необходимости;

- разрешить доступ к конфиденциальной информации только тем сотрудникам, для которых она необходима для выполнения их обязанностей.

10.6 Обучение пользователей

Все сотрудники должны проходить соответствующее обучение и переподготовку по вопросам информационной безопасности, организуемое Университетом. Соответствующее обучение следует начинать с ознакомления с Политикой информационной безопасности в Университете до предоставления доступа к информации и услугам.

10.7 Оповещение о нарушениях

Пользователи должны немедленно сообщать о любых подозрительных событиях или инцидентах безопасности Офицеру информационной безопасности или Системному администратору.

Глава 11. Обязанности персонала по обеспечению безопасности

11.1 Офицер информационной безопасности организует, выполняет, контролирует и координирует вопросы и работы, связанные с защитой информации и осуществляет:

- контроль за исполнением требований Политики ИБ;
- разработку, внедрение и актуализацию четырехуровневой документации ИБ;
- контроль за управлением активами в части обеспечения информационной безопасности;
- контроль законности использования программного обеспечения;
- контроль за управлением рисками;
- контроль за регистрацией событий информационной безопасности;
- проведение планового и внепланового аудита информационной безопасности;
- подготовка к внешним аудитам ИБ и проверкам;
- управление непрерывностью бизнес-процессов и контроль за его осуществлением;
- контроль соблюдения требований информационной безопасности при управлении персоналом;
- контроль и внедрение функционирования системы обеспечения

информационной безопасности;

- организацию и проведение обучения сотрудников по вопросам ИБ, разъяснение норм Политики ИБ.

11.2 Для достижения поставленных задач в области информационной безопасности Офицер информационной безопасности имеет право:

- мониторить и контролировать информационно-коммуникационную инфраструктуру Университета;
- доступа во все помещения Университета, где установлены: средства вычислительной техники, локальная сеть и средства обработки информации Университета;
- осуществлять прекращение автоматизированной обработки информации при наличии непосредственной угрозы для защищаемой информации.

11.3 Начальник управления информационных технологий отвечает за техническое обеспечение информационной безопасности, включая защиту ИТ-инфраструктуры, серверов, сетевых ресурсов и пользовательских устройств. Он координирует работу системных администраторов и гарантирует, что все технические средства и процедуры соответствуют установленным требованиям безопасности.

11.4 Системные администраторы обеспечивают непрерывное функционирование сети и отвечают за реализацию технических мер, необходимых для проведения в жизнь политики безопасности.

Глава 12. Ответственность за нарушение Политики

12.1 Все сотрудники, обучающийся и третьи лица, имеющие доступ к информационным системам и ресурсам Университета, обязаны строго соблюдать Политику ИБ и внутренние нормативные документы.

12.2 Нарушение Политики ИБ включает действия или бездействие, которые могут привести к утечке, утрате, искажению или несанкционированному доступу к защищаемой информации.

12.3 В зависимости от характера и тяжести нарушения могут быть применены следующие меры:

- Дисциплинарные меры: замечание, выговор, строгий выговор, временное отстранение от должности или прекращение трудового договора;
- Материальная ответственность: возмещение ущерба, причинённого Университету;
- Юридическая ответственность: привлечение к административной или уголовной ответственности в соответствии с законодательством Республики Казахстан.

Глава 13. Заключительные положения

13.1 Политика информационной безопасности должна быть подвергнута анализу и пересмотру один раз в год или при возникновении существенных

изменений для обеспечения требованиям соответствия, адекватности и эффективности.

13.2 В ходе пересмотра следует оценить возможность улучшения положений Политики информационной безопасности и процесса управления информационной безопасностью в соответствии с изменениями условий ведения бизнеса, законодательства, изменениями в организационной структуре или информационной системе организации.

13.3 Необходимо ведение записей пересмотра Политики.

13.4 Пересмотренная Политика информационной безопасности должна быть утверждена соответствующим должностным лицам или руководством Университета.

ЛИСТ РЕГИСТРАЦИИ ИЗМЕНЕНИЙ К _____

(обозначение документа)

№	Раздел, пункт документа	Вид изменения (заменить, аннулировать, добавить)	Номер и дата извещения	Изменение внесено	
				Дата	Фамилия и инициалы, подпись, должность

Алматы, 2025